

Code Quality & Security Audit Report

Comprehensive Static Code & Dependency Analysis

PROJECT	DART SDK	TARGET PLATFORMS	STATE / NETWORK
flutter_architect_mcp	^3.10.3	Android, iOS	setState / HttpClient (Default)

1. Executive Summary & Category Breakdown

CATEGORY	HIGH SEVERITY	MEDIUM SEVERITY	LOW SEVERITY	TOTAL ISSUES
Security & Secrets	1	2	1	4
Performance & UI Lag	4	1	0	5
Memory & Lifecycle Leaks	2	8	0	10
Maintainability & Class Size	0	0	12	12
Total Detected Issues	7	11	13	31

2. Critical Security Findings

RULE ID	SEVERITY	FILE LOCATION	LINE	FINDING DETAILS & RISK
SEC-ATH-002	MEDIUM	lib/security/scanners/auth_scanner.dart	1	Incomplete Logout Implementation: The logout function in lib/security/scanners/auth_scanner.dart does not appear to clear local authentication tokens or cache. <i>Risk: If local storage is not wiped during logout, another user or an attacker could potentially access the preceding session.</i>
SEC-ATH-001	HIGH	templates/shared/utils/helper/shared_pref_helper.dart	13	Potential Hardcoded Password or Auth Key: Found variable assignment indicating a hardcoded password or token: "String deviceToken = 'deviceToken'" <i>Risk: Hardcoding passwords in code makes them accessible to any attacker who extracts the application binary.</i>
SEC-WV-001	MEDIUM	templates/shared/common/reusable_component/widgets/web_view.dart	1	WebView JavaScript Execution Enabled Unrestrictedly: Detected a WebView instantiated with unrestricted JavaScript execution enabled. <i>Risk: Enabling JavaScript in WebViews allows loaded pages to execute code. If untrusted remote content is displayed, it could lead to Cross-Site Scripting (XSS) attacks compromising local app data or bridge APIs.</i>
SEC-DEP-INFO	LOW	pubspec.yaml	1	Vulnerability Database Check Status: Using built-in offline Dart/Flutter security rules database. Remote live vulnerability database check is not configured. <i>Risk: None. This is an informational message stating that live CVE lookup from OSV/GitHub Advisory is not active.</i>

Security Remediation Action Items

- Ensure SharedPreferences, Hive boxes, and local caches are cleared or deleted when the user logs out.
- Retrieve passwords dynamically from user input or encrypted vaults.
- Only enable JavaScript if strictly required. Ensure that navigation is restricted to HTTPS and approved domains using navigation delegates.
- Periodically check dependencies using GitHub security alerts or running "dart pub token" or external tools.

3. High-Priority Performance Flaws: Controller in build()

Instantiating controllers inside build() forces memory re-allocations on every frame render, causing UI stutter, dropped text inputs, and lost scroll states.

COMPONENT / AREA	FILE PATH	LINE	ISSUE DESCRIPTION
Performance Engine	lib/performance/performance_engine.dart	100	Use of Static ListView Instead of Lazy ListView.builder
App Text Form Field	templates/shared/common/reusable_component/widgets/app_text_form_field.dart	38	Controller Instantiation Inside Widget build() Method
Dropdown Overlay	templates/shared/common/reusable_component/widgets/custom_dropdown/dropdown_overlay/dropdown_overlay.dart	109	Controller Instantiation Inside Widget build() Method
Items List	templates/shared/common/reusable_component/widgets/custom_dropdown/dropdown_overlay/widgets/items_list.dart	25	Controller Instantiation Inside Widget build() Method
Common Transaction List	templates/shared/common/reusable_component/widgets/trasaction_lists/common_transaction_list.dart	69	Controller Instantiation Inside Widget build() Method

Standard Fix Architecture:

```
class _SafeInputWidgetState extends State<SafeInputWidget> {
  late final TextEditingController _controller;

  @override
  void initState() {
    super.initState();
    _controller = TextEditingController(); // Allocated once
  }

  @override
  void dispose() {
    _controller.dispose(); // Safely freed from memory
    super.dispose();
  }

  @override
  Widget build(BuildContext context) => TextField(controller: _controller);
}
```

4. Memory & Resource Leaks

ISSUE TYPE	FILE PATH	LINE	HAZARD
MEM-001 (MEDIUM)	scratch/test_draft.dart	8	Potential StreamSubscription Memory Leak

ISSUE TYPE	FILE PATH	LINE	HAZARD
MEM-001 (MEDIUM)	lib/tools/scanners_and_audit_reports/run_runtime_perf.dart	30	Potential StreamSubscription Memory Leak
MEM-002 (MEDIUM)	lib/tools/runtime_perf_check/perf_dashboard_html.dart	364	Potential Timer Memory Leak
MEM-001 (MEDIUM)	lib/tools/runtime_perf_check/perf_server.dart	47	Potential StreamSubscription Memory Leak
MEM-002 (MEDIUM)	lib/tools/runtime_perf_check/client_integration.dart	122	Potential Timer Memory Leak
MEM-001 (MEDIUM)	templates/shared/utils/helper/deep_link_helper.dart	78	Potential StreamSubscription Memory Leak
MEM-001 (MEDIUM)	templates/shared/utils/helper/notification_sender_helper.dart	145	Potential StreamSubscription Memory Leak
MEM-001 (MEDIUM)	templates/shared/utils/helper/connectivity.dart	25	Potential StreamSubscription Memory Leak
MEM-003 (HIGH)	templates/shared/common/reusable_component/dialogs/dispute_dialog.dart	15	Potential Memory Leak: Un-disposed TextEditingController
MEM-003 (HIGH)	templates/shared/common/reusable_component/widgets/trasaction_lists/common_transaction_list.dart	39	Potential Memory Leak: Un-disposed ScrollController

5. Class Bloat & Technical Debt (Files > 500 LOC)

FILE LOCATION	LINES	CATEGORY / FOCUS AREA	ARCHITECTURAL ACTION
bin/server.dart	1238	General	Break down the class or widgets into smaller, modular helper components or service classes.
lib/tools/runtime_perf_check/perf_pdf_generator.dart	587	General	Break down the class or widgets into smaller, modular helper components or service classes.
lib/tools/runtime_perf_check/perf_dashboard_html.dart	815	General	Break down the class or widgets into smaller, modular helper components or service classes.
templates/shared/common/reusable_component/toast/flushbar.dart	791	General	Break down the class or widgets into smaller, modular helper components or service classes.
templates/shared/common/reusable_component/widgets/common_debit_card.dart	532	General	Break down the class or widgets into smaller, modular

FILE LOCATION	LINES	CATEGORY / FOCUS AREA	ARCHITECTURAL ACTION
			helper components or service classes.
templates/shared/common/reusable_component/widgets/trasaction_lists/common_transaction_list.dart	766	General	Break down the class or widgets into smaller, modular helper components or service classes.

6. Unresolved Production TODOs

FILE PATH	LINE	MISSING FEATURE / INCOMPLETE CODE
templates/shared/common/reusable_component/widgets/keyboard_config.dart	3	in future remove
templates/shared/common/reusable_component/widgets/web_view.dart	23	implement initState
templates/shared/common/reusable_component/widgets/trasaction_lists/common_trsaction_list_bloc.dart	8	implement dispose
templates/shared/common/reusable_component/widgets/trasaction_lists/common_transaction_list.dart	64	implement initState
templates/shared/common/reusable_component/widgets/trasaction_lists/common_transaction_list.dart	523	remove +/- symbol removed
templates/shared/common/reusable_component/widgets/trasaction_lists/common_transaction_list.dart	570	Sprint 2

7. Recommended Action Plan

Phase 1 — Hotfix (Days 1–2):

- Ensure SharedPreferences, Hive boxes, and local caches are cleared or deleted when the user logs out.
- Retrieve passwords dynamically from user input or encrypted vaults.
- Only enable JavaScript if strictly required. Ensure that navigation is restricted to HTTPS and approved domains using navigation delegates.

Phase 2 — Performance & Memory (Days 3–5):

- Refactor to "ListView.builder(...)" to enable lazy-loading and item recycling for better scrolling performance.
- Convert the widget to a StatefulWidget and instantiate controllers in initState() and dispose them in dispose().
- Store the StreamSubscription in a variable and call subscription.cancel() in dispose() or onClose().

Phase 3 — Refactoring & Debt (Week 2):

- Break down the class or widgets into smaller, modular helper components or service classes.
- Break down the class or widgets into smaller, modular helper components or service classes.
- Address pending TODO comments in templates/shared/common/reusable_component/widgets/keyboard_config.dart at line 3.

8. Analysis Criteria Observed

The project is audited against the following rules:

Code Quality ■ Proper use of const and final: If widget not updated once declare and variable value will never change once declare then use const and final with decoration (Threshold: <code>const_possible == true assignment_count == 1</code>) ■ Large File LOC: Trigger when a file has more than 500 non-empty, non-comment code lines (Threshold: <code>file_code_loc > 500</code>) ■ Large Class LOC: Trigger when a class exceeds configured LOC threshold (Threshold: <code>class_code_loc > 300</code>) ■ Large Function LOC: Trigger when a function/method exceeds configured LOC threshold (Threshold: <code>function_code_loc > 80</code>) ■ Unused Widgets/Classes/Functions: Declared widget/class/function has no references (Threshold: <code>reference_count == 0</code>) ■ Unused Imports: Imported symbol is never referenced (Threshold: <code>import_reference_count == 0</code>) ■ Unreachable Branch: Branch can never execute based on static control-flow analysis (Threshold: <code>unreachable == true</code>) ■ High Cyclomatic Complexity: Function exceeds complexity threshold (Threshold: <code>complexity > 10</code>)	Security ■ Hardcoded API Key: API key pattern detected in source/config (Threshold: <code>Pattern + entropy score</code>) ■ Payment Gateway Credential: Payment provider private/secret credential detected (Threshold: <code>Provider pattern</code>) ■ Firebase Service Account: Firebase service-account JSON/private key detected (Threshold: <code>Credential pattern</code>) ■ Private Key/Certificate: PEM/private key/signing material detected (Threshold: <code>private_key_detected == true</code>) ■ Insecure Token Storage: Access/refresh tokens stored in SharedPreferences/plain files (Threshold: <code>Sensitive token + insecure storage</code>) ■ HTTP/Cleartext Traffic: Non-TLS HTTP endpoint or cleartext platform configuration detected (Threshold: <code>http:// / cleartext enabled</code>) ■ Certificate Validation Bypass: Client bypasses certificate validation (Threshold: <code>Trust-all callback/API</code>) ■ Unsafe WebView Configuration: JavaScript/file access/untrusted navigation enabled without controls (Threshold: <code>Risk pattern</code>) ■ Unsafe Dynamic Data Handling: Unsafe eval-like/dynamic deserialization or execution pattern detected (Threshold: <code>Risk API pattern</code>)
--	--

- **Duplicate Code:** Similar code block exceeds configured similarity threshold (Threshold: similarity >= 0.85)
- **Large Build Method:** Build method exceeds configured size (Threshold: build_loc > 80)
- **Deep Widget Nesting:** Widget tree nesting exceeds threshold (Threshold: depth > 8)
- **Broad State Rebuild:** State update potentially rebuilds unnecessarily large widget subtree (Threshold: Configurable)
- **Missing Const Opportunity:** Constructor/widget can safely be const but is not (Threshold: const_possible == true)
- **Improper final Usage:** Local variable never reassigned and can be final (Threshold: assignment_count == 1)
- **Unsafe Late Usage:** late variable may be accessed before initialization or is unnecessary (Threshold: Configurable)
- **Naming Convention Violation:** Classes, variables, methods/files violate Dart naming conventions (Threshold: Dart convention)
- **Empty Catch Block:** Catch block has no meaningful handling/logging/rethrow (Threshold: catch_body_effective_statements == 0)

- **Sensitive Data in Logs:** Token/password/payment/PII passed to logging APIs (Threshold: Sensitive variable/pattern)
- **Android Insecure Configuration:** Debuggable release config, exported components or permissive network settings (Threshold: Risk configuration)
- **iOS Insecure Configuration:** ATS exceptions, insecure entitlements or overly permissive settings (Threshold: Risk configuration)
- **Overly Permissive Firebase Rules:** Firestore/Realtime Database allows broad unauthenticated read/write (Threshold: Broad read/write access)

Memory Leak

- **Unclosed StreamSubscription:** StreamSubscription created without matching cancellation/disposal (Threshold: cancel_missing == true)
- **Unclosed Timer:** Timer created without cancellation (Threshold: cancel_missing == true)
- **AnimationController Not Disposed:** AnimationController created in State without dispose (Threshold: dispose_missing == true)
- **TextEditingController Not Disposed:** TextEditingController retained without disposal (Threshold: dispose_missing == true)
- **Scroll/Page Controller Not Disposed:** ScrollController/PageController created without disposal (Threshold: dispose_missing == true)
- **Listener Not Removed:** addListener/addObserver without matching remove (Threshold: remove_missing == true)
- **Unnecessary StatefulWidget:** StatefulWidget has no mutable state or lifecycle requirement (Threshold: stateful_need == false)
- **Missing Const StatelessWidget:** Immutable widget does not use const constructor (Threshold: const_possible == true)
- **Long-Lived Closure Captures State/Context:** Long-lived callback captures State/BuildContext (Threshold: Risk pattern)
- **Unbounded In-Memory Collection:** List/map/cache grows without size/eviction control (Threshold: Configurable size/eviction rule)

Runtime Analysis

- **Heap Growth Over Time:** Heap increases across repeated flows and does not return toward baseline (Threshold: Configurable growth %)
- **Widget/Object Retention:** Objects remain retained after route/widget disposal (Threshold: Retained after disposal)
- **Frame Rendering/Jank:** Frame build/raster time exceeds threshold or dropped frames detected (Threshold: frame_time > 16.67ms)
- **Excessive Widget Rebuilds:** Widget rebuild count significantly exceeds expected baseline (Threshold: Configurable multiplier)
- **Slow Startup:** Cold-start time exceeds configured threshold (Threshold: startup_ms > 3000)
- **Slow API Request:** API request exceeds latency threshold (Threshold: latency_ms > 2000)
- **Excessive Network Traffic:** Unexpected request frequency or payload volume (Threshold: Configurable request/payload threshold)
- **Unhandled Exception:** Unhandled Dart/Flutter exception during test flow (Threshold: unhandled_exception == true)
- **Resource Retained After Screen Exit:** Subscription/timer remains active after navigation away (Threshold: Active resource after dispose)
- **Sensitive Runtime Storage:** Token/payment/PII written to logs or insecure storage (Threshold: Sensitive data detected)

Dependencies

- **Vulnerable Package Version:** Direct/transitive dependency has known security advisory (Threshold: Known CVE/advisory)
- **Unused Dependency:** Declared package has no project references (Threshold: reference_count == 0)
- **Unmaintained Package:** Package has stale releases or weak maintenance signals (Threshold: Configurable inactivity period)

Architecture

- **Layer Violation:** UI directly accesses infrastructure/data layer against selected architecture (Threshold: Forbidden dependency)
- **Mixed State Management:** Conflicting state-management patterns used across modules (Threshold: Configured allowed patterns)
- **Business Logic Inside Widget:** Networking/business rules embedded in build/UI classes (Threshold: Configurable complexity/API count)

Reporting

- **File/Line/Code Evidence:** Every finding must include exact source location and evidence snippet (Threshold: Required fields)
- **Severity/Confidence Scoring:** Every finding receives severity and confidence (Threshold: Required fields)
- **Suppression/Ignore Support:** Approved findings can be suppressed with a reason (Threshold: Suppression requires reason)

Local Threshold Parameters

- **Max Lines of Code:** 500
- **Max Function Lines:** 50
- **Allow TODO:** false
- **Enforce class prefixes:** true